CASE STUDY

Sandworm: The Operations in the Public Record

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

For people who defend power grids, shipping lines, hospitals and election infrastructure, one crew has shaped the threat model more than any other in the past decade. Researchers call it Sandworm. Governments call it Unit 74455 of Russia's military intelligence service, the GRU. Between 2015 and 2022 it turned the lights off in Ukraine three times, released NotPetya, which the White House called the most destructive and costly cyber attack in history, wiped computers at the opening ceremony of an Olympic Games while dressing the attack up as North Korean work, and, by the NCSC's later account, infected hundreds of thousands of home and office routers and storage devices [42] [46]. Andy Greenberg's 2019 book *Sandworm* told much of that story for a general audience. This study goes back to the record underneath it: the vendor reports, government alerts, company filings and the October 2020 US indictment of six GRU officers [5].

The record is unusually strong. A grand jury indictment names the officers and charges the 2015 and 2016 grid attacks, NotPetya, the PyeongChang attack and the 2019 Georgia attack [5] (**Confirmed**). The UK, US State Department and White House made public attributions [32] [33] [34] [47] [72] (**Confirmed**). Vendors such as ESET, Cisco Talos, Kaspersky, Dragos and Mandiant published the technical detail. Where the book is the only source, this study says so and grades the claim **Reported**.

> Evidence grade: the operations, their dates and their mechanics are **Confirmed** from primaries. Victim losses are **Confirmed** where a company filing states them and **Reported** where only the book does. Links between toolsets rest on vendor assessments, stated as such.

Key facts at a glance

Field	Value
Names	Sandworm Team (ATT&CK `G0034`, v4.2, modified 31 July 2026); also ELECTRUM, Telebots, IRON VIKING, BlackEnergy (Group), Quedagh, Voodoo Bear, IRIDIUM, Seashell Blizzard, FROZENBARENTS, APT44 [14]
Sponsor	GRU Military Unit 74455, also called the GTsST, in Khimki [5] [47]
Active since	At least 2009 per ATT&CK [14]
Indictment	*United States v. Andrienko et al.*, W.D. Pa. Criminal No. 20-316, filed 15 October 2020; six officers; seven counts [5]
First blackout	23 December 2015: three Ukrainian distribution companies, about 225,000 customers [1]
Second blackout	17 December 2016: a Kyiv transmission substation, about one hour [5] [9]
Third blackout	10 October 2022: a Ukrainian utility, via its own MicroSCADA software [58]
Costliest attack	NotPetya, 27 June 2017; FedEx put its cost at about $400 million and Merck reported hundreds of millions in lost sales and costs [28] [25]
False flag	Olympic Destroyer, 9 February 2018, written to look like Lazarus Group code [5] [40]
Edge-device botnet	VPNFilter, at least 500,000 devices in at least 54 countries (May 2018) [42]
ATT&CK record	Campaigns `C0028` (2015), `C0025` (2016), `C0034` (2022); live G0034 lists 98 Enterprise, 27 ICS and 3 Mobile technique entries [14]
This study binds	78 Enterprise and 49 ATT&CK for ICS techniques to dated events (Part 13)

Key findings

- **The 2015 blackout was done by hand, not by malware.** BlackEnergy was on every victim network, but the outage came from operators opening breakers through the utilities' own control screens over VPN, probably with previously obtained legitimate credentials [2] [1]; the indictment alleges BlackEnergy was used to steal them [5] (**Confirmed**). KillDisk and malicious converter firmware then made recovery harder [1] (**Confirmed**).
- **The 2016 attack automated what 2015 did manually.** Industroyer carried payloads for four industrial protocols and was triggered at set times [11] (**Confirmed**). Its real-world effect was a brief outage, and its protection-relay attack failed because of a byte-order bug [9] (**Confirmed**).
- **NotPetya was a supply-chain wiper dressed as ransomware.** It arrived through backdoored updates of the Ukrainian accounting package M.E.Doc [20] and CISA judged recovery unlikely [23]. The indictment calls the $300 ransom a ruse [5] (**Confirmed**).
- **The losses are on the record in company filings.** FedEx reported about $400 million [28] and Mondelez $84 million in incremental expenses [29]. Merck reported a $260 million sales hit and about $285 million in costs for 2017 [25] (**Confirmed**). Greenberg's per-company figures and the more than $10 billion total are **Reported** [31].

- **The false flag at PyeongChang was caught by analysts.** Kaspersky showed the wiper's Rich header had been forged to match Lazarus code [40], and the indictment says the code was written to emulate Lazarus [5] (**Confirmed**).
- **Edge devices are part of this actor's battlefield.** VPNFilter and its successor Cyclops Blink lived on routers, NAS boxes and firewalls; VPNFilter could brick them [42] [48] (**Confirmed**).
- **The pattern held in 2022.** Industroyer2 [54] [55] and a MicroSCADA-based outage [58] repeated the grid playbook, and both were paired with wipers pushed through Group Policy (**Confirmed**).
- **The library needs corrections.** `THREAT_ACTORS.md` places Olympic Destroyer under APT28, `MALWARE_FAMILIES.md` over-attributes the 2022 wipers, and `NOTABLE_INCIDENTS.md` has no entry for the 2015 or 2016 grid attacks (Part 12).

Top recommendations

1. **Put multi-factor authentication on every path into the control network.** The 2015 VPNs into the ICS appear to have lacked two-factor authentication [2], and the operators probably used previously obtained legitimate credentials [1], which the indictment alleges BlackEnergy stole [5]. This recommendation is **Inferred** from that record.
2. **Isolate ICS from untrusted networks and close remote access you do not need.** CISA advised this after 2015 [1]. After 2016 it advised enclaves, removing modems, monitoring-only access through data diodes and allowlisting on HMIs [10].
3. **Plan restoration around gold disks and manual operation.** Malicious converter firmware and UPS disconnects hampered restoration [1], and KillDisk left systems inoperable [1] [5]. ICS Data Backup (M0953) and Out-of-Band Communications Channel (M0810) appear among the most frequent mitigations for these techniques (Part 13.6).
4. **Treat software updates as a privileged channel.** M.E.Doc's update server delivered NotPetya to its customers [20]. Watch what updaters launch: Microsoft saw the M.E.Doc updater EzVit.exe run the malicious command line [22].
5. **Patch SMBv1 and contain credential theft.** EternalBlue and EternalRomance were patched on 14 March 2017 [23], but NotPetya's first and usually most effective spread was modified Mimikatz with stolen credentials [23].
6. **Monitor Group Policy changes and abuse of native tools.** In 2022 wipers went out through GPO [52] [55] [58], and the October 2022 outage used the vendor's own binary [58]. Allowlisting alone would not have stopped that (Part 11) (**Inferred**).
7. **Count routers and firewalls as grid assets.** The FBI's first advice on VPNFilter was to reboot [44], and Cyclops Blink went after devices exposed for remote management [48]. Inventory edge devices and close management interfaces you do not need (**Inferred**).

Scope and method

This study covers Sandworm's publicly documented operations from the 2014 disclosure of the Windows zero-day it delivered in Office documents (CVE-2014-4114) through the 2022 attacks on Ukraine and the 2024 APT44 designation. It is the home study for Sandworm's operations: other studies in the series that touch the 2019 Georgia attack, the 2020 indictment or NotPetya, such as The Year 2019 in Intrusions: A Dated Record and The Year 2020 in Intrusions: A Dated Record, summarize them and link here. Sandworm's ICS-related activity from 2024 on, including the contested December 2025 attack in Poland, has its home in Industrial Control System Attacks and Advisories, 2024 to 2026. It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 3 November 2026. A book is a secondary source. Greenberg's account was read through the WIRED excerpts of the book, not a printed copy [31] [62] [71], and claims that only the book makes are graded **Reported** and attributed to it by title and author. Direct quotations are kept under 15 words.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the vendor or lab that did the analysis, a government agency, a court record, a company filing, or the MITRE page itself
Reported	Stated only in journalism, the book or a secondary source relaying another party; the original was not opened or does not exist publicly
Demonstrated	A public reproduction exists that others can check (no claim in this study needed this grade)
Inferred	This study's reasoning from the cited sources, labelled where it appears

A note on counts: figures for the 2015 blackout differ across primaries. ICS-CERT and the SANS/E-ISAC report give about 225,000 customers [1] [2]. ESET's 2017 summary says about 250,000 households [4], and the UK government says 230,000 people [47]. This study uses 225,000 customers.

Part 1: identity and aliases

1.1 One unit, many names

Each vendor that tracked this activity named it for what it saw. In Greenberg's account, John Hultquist's team first spotted and named Sandworm in 2014 and found Russian-language BlackEnergy instructions on an unsecured command server [62] (**Reported**). WIRED's text calls that team FireEye. Microsoft's October 2014 bulletin MS14-060, which fixed the flaw the campaign used, credits iSIGHT Partners and ESET researchers [63] (**Confirmed**). The bulletin's acknowledgment points to iSIGHT Partners rather than FireEye (**Inferred**).

ESET tracked the 2015 to 2017 activity as the BlackEnergy group and then TeleBots, and reported that TeleBots macros matched the BlackEnergy group's 2015 macros [70] (**Confirmed**). Dragos named the 2016 operator ELECTRUM and assessed it as linked to Sandworm, possibly as its ICS development team [13] (**Confirmed**). Microsoft tracked IRIDIUM, now Seashell Blizzard [57]. On 17 April 2024 Mandiant graduated the group to APT44 (FROZENBARENTS) [60] (**Confirmed**). ATT&CK records all of these as associated names of G0034 [14] (**Confirmed**).

1.2 The government identification

The October 2020 indictment equates GRU Military Unit 74455, which it says is also called the GTsST and "the Tower" at 22 Kirova Street in Khimki, with Sandworm Team, Telebots, Voodoo Bear and Iron Viking [5] (**Confirmed**). The UK government named the GTsST, field post 74455, as the unit behind Sandworm, BlackEnergy Group, Telebots and VoodooBear on 20 February 2020 [47] (**Confirmed**). The US State Department said the same day that the GTsST is also known as Unit 74455 and Sandworm [72] (**Confirmed**). Greenberg's 2019 book had already reached that identification [71] (**Reported**). Its later confirmation by three primaries is this study's reading of the dates (**Inferred**).

1.3 The defendants

Defendant	Role alleged in the indictment [5]
Yuriy Andrienko	Developed NotPetya and Olympic Destroyer components; worked on an obfuscation algorithm
Sergey Detistov	Developed NotPetya components
Pavel Frolov	Developed NotPetya components and the KillDisk variant used against Ukraine's Ministry of Finance
Anatoliy Kovalev	Sent spearphishing against the French election, the Olympics, DSTL and Georgia
Artem Ochichenko	Targeted Olympic timekeeping partners and, in 2019, Georgia's Parliament
Petr Pliskin	Developed NotPetya and Olympic Destroyer components

The FBI's wanted notice for Andrienko lists the same six defendants and the same targets [73] (**Confirmed**). These are charged allegations; no defendant has been tried.

Part 2: the operational record

Each row is one operation or one report. Grades apply to the row's central claim.

Date	Operation or report	What the record says	Sources	Grade
2011 to 2014	BlackEnergy against internet-facing HMIs	GE CIMPLICITY, Siemens WinCC and Advantech/Broadwin WebAccess targeted; CVE-2014-0751 exploited from at least January 2012	[8]	Confirmed
14 Oct 2014	MS14-060 patched	CVE-2014-4114, exploited in the wild in a Sandworm campaign; credit to iSIGHT Partners and ESET	[63] [64]	Confirmed
Oct 2015	Ukrainian media	Kaspersky notes STB TV was publicly mentioned as a victim of BlackEnergy wiper attacks; Greenberg's account of StarLightMedia	[6] [62]	Confirmed (Kaspersky); Reported (StarLightMedia)
Nov 2015	Local elections	ESET reports that CERT-UA documented KillDisk against news media	[7] [67]	Confirmed (ESET's report); CERT-UA original not opened
Mar to Dec 2015	Grid intrusion	Spearphishing with macro Office files from spring 2015; access gained more than six months before the outage	[2] [5]	Confirmed

Date	Operation or report	What the record says	Sources	Grade
27 Jul 2015	BlackEnergy Word lure	$RR143TB.doc drops vba_macro.exe; Kaspersky does not tie it to the outage	[6]	Confirmed
23 Dec 2015	First Ukrainian blackout	Three distribution companies, about 225,000 customers, attacks within 30 minutes of each other	[1] [2]	Confirmed
2016	Ministry of Finance and State Treasury	About 150,000 transactions blocked; Frolov built the KillDisk variant	[5]	Confirmed (charged)
17 Dec 2016	Kyiv transmission substation	Industroyer; about one hour of disruption	[5] [9] [11]	Confirmed
Jan to Mar 2017	Earlier TeleBots supply-chain attacks	ESET documents attacks against Ukraine before NotPetya	[21]	Confirmed
2017	French presidential campaign	Spearphishing of the French presidential campaign	[5]	Confirmed (charged)
14 Apr to 22 Jun 2017	M.E.Doc backdoor	Backdoored builds released; the indictment dates the third modification 21 June, Talos 22 June	[20] [5]	Confirmed
18 May 2017	XData ransomware	Also used M.E.Doc as its vector	[21]	Confirmed
27 Jun 2017	NotPetya	Worldwide destructive outbreak from the M.E.Doc update server, on Ukraine's Constitution Day	[20] [22] [23] [60]	Confirmed
24 Oct 2017	Bad Rabbit	Watering-hole ransomware; Kyiv metro, Odessa airport, Russian central bank	[36] [37] [34]	Confirmed
Dec 2017 to Feb 2018	PyeongChang preparation	Domains spoofed, mobile apps, IT companies compromised, 16,000 hosts' credentials dumped	[5]	Confirmed (charged)
Jan 2018	Georgian media outlet	Eight spearphishing emails to 68 addresses	[5]	Confirmed (charged)
9 Feb 2018	Olympic Destroyer	Wiper pushed during the opening ceremony	[5] [39]	Confirmed
Apr 2018	OPCW and DSTL	Spearphishing of the nerve-agent investigators	[5]	Confirmed (charged)
May to Jun 2018	Olympic Destroyer returns	Spiez Laboratory and Salisbury-themed lures	[41]	Confirmed
23 May 2018	VPNFilter disclosed	At least 500,000 devices in at least 54 countries; spikes in Ukraine on 8 and 17 May	[42]	Confirmed
6 Jun 2018	VPNFilter update	More vendors; ssler and dstr modules	[43]	Confirmed
11 Oct 2018	Exaramel	ESET's code link from Industroyer to TeleBots and NotPetya	[35]	Confirmed
From Jun 2019	Cyclops Blink deployed	VPNFilter replacement on WatchGuard devices	[48]	Confirmed
31 Jul 2019	Georgia Parliament	Technical reconnaissance and attempted access	[5]	Confirmed (charged)

Date	Operation or report	What the record says	Sources	Grade
28 Oct 2019	Georgia	About 15,000 websites defaced; broadcasters interrupted	[5] [47] [72]	Confirmed
20 Feb 2020	UK and US attribution of Georgia	UK: GRU "almost certainly (95%+)" responsible [47]; US State Department: GTsST, Unit 74455, Sandworm [72]	[47] [72]	Confirmed
15 Oct 2020	Indictment filed	Six officers of Unit 74455	[5]	Confirmed
15 Feb 2021	Centreon campaign report	ANSSI: late 2017 to 2020, P.A.S. webshell, similarities with Sandworm	[74]	Confirmed
13 Jan 2022	WhisperGate	Microsoft tracks the actor as DEV-0586 (Cadet Blizzard), distinct from Sandworm	[51]	Confirmed
23 Feb 2022	Cyclops Blink advisory	NCSC, CISA, NSA and FBI attribute it to Sandworm	[48] [49]	Confirmed
23 Feb 2022	HermeticWiper	ESET could not attribute it	[52]	Confirmed
24 Feb 2022	Viasat KA-SAT	UK: Russia almost certainly responsible (does not name Sandworm); AcidRain	[59] [45]	Confirmed
14 Mar 2022	CaddyWiper	Several dozen systems; ESET named no actor	[53]	Confirmed
8 Apr 2022	Industroyer2	Planned against high-voltage substations; CERT-UA says the attack was prevented	[54] [55]	Confirmed
10 to 12 Oct 2022	Third Ukrainian blackout	MicroSCADA scilc.exe, then CaddyWiper	[58]	Confirmed
11 Oct 2022	Prestige	Ransomware in Ukraine and Poland; Microsoft assessed IRIDIUM very likely	[57]	Confirmed
17 Apr 2024	APT44	Mandiant designation	[60]	Confirmed
Mar to Dec 2025	Poland wiper attacks (`C0063`)	ATT&CK carries split attribution between Dragonfly and ELECTRUM/Sandworm	[76]	Confirmed

Part 3: the 2015 blackout

3.1 Getting in

The intrusion began with spearphishing. Macro-enabled Excel and Word attachments carried BlackEnergy 3; no exploit code was found, because the macro feature itself was abused [2] (**Confirmed**). The SANS/E-ISAC report charts the operation from March 2015 [2], and the indictment says the phishing began in late spring 2015 and targeted IT staff and system administrators [5] (**Confirmed**). Kaspersky documented one such lure, a Word file with metadata dated 27 July 2015. Its macro drops vba_macro.exe, writes FONTCACHE.DAT, runs it with rundll32 and adds a Startup-folder shortcut, with HTTP POST command and control [6] (**Confirmed**). Kaspersky does not tie that sample to the outage, and noted that macro-laden Excel files were the preferred vector from mid-2015 [6].

The indictment alleges that BlackEnergy was used to steal credentials that were then used to reach the SCADA networks [5] (**Confirmed** as charged). The VPNs from the business network into the ICS appear to have lacked two-factor authentication [2] (**Confirmed**). ESET found a modified Dropbear SSH server, SSHBearDoor, started by a VBS script on port 6789 with a hard-coded password, used as a backdoor against both media and electricity companies [7] (**Confirmed**).

3.2 The outage

On 23 December 2015 three regional distribution companies (oblenergos) lost power to about 225,000 customers; three other organizations were intruded upon with no operational impact [1] (**Confirmed**). The attacks came within 30 minutes of each other [2]. At Kyivoblenergo, from about 3:35 p.m. local time, seven 110 kV and 23 35 kV substations were disconnected for about three hours [3] (**Confirmed**). At least 27 substations were taken offline across the three companies, and SANS/E-ISAC assess with medium confidence that the true number is higher [2].

Multiple external operators opened breakers remotely, using operating-system remote administration tools or remote ICS client software over VPN [1] (**Confirmed**). The three companies ran three different distribution management systems. The attackers learned each one through its native operator screens, with no exploits against the DMS vendors, and at least one company's operators were locked out of their workstations [2] (**Confirmed**). Greenberg tells this through a "phantom" mouse moving across a Prykarpattyaoblenergo screen [62] (**Reported**).

3.3 Slowing the recovery

Two moves were aimed at restoration, and a third at the utilities' customers. The attackers wrote malicious firmware for substation serial-to-Ethernet converters and uploaded it to multiple sites, so remote commands could not bring substations back; SANS assesses with high confidence that the firmware was tested first [2] (**Confirmed**). They scheduled disconnects of server uninterruptible power supplies through the UPS management interface [1]. A telephone denial of service flooded at least one call center with thousands of calls, more likely to frustrate customers than to hide the outage, in the SANS/E-ISAC judgment [2] (**Confirmed**).

A modified KillDisk erased selected files and corrupted master boot records. In at least one case it overwrote Windows-based HMI cards embedded in RTUs; on some systems it only deleted logs [1] (**Confirmed**). ESET's analysis of the energy-sector variant shows a command-line delay, deletion of the Application, Security, Setup and System event logs, 35 targeted file extensions, and termination of komut.exe and sec_service.exe, the latter possibly serial-to-Ethernet software [7] (**Confirmed**).

3.4 What BlackEnergy did and did not do

BlackEnergy was found on each company's network, but neither BlackEnergy 3 nor KillDisk caused the outage, which came from direct interactive use of the control systems [2] (**Confirmed**). ICS-CERT said BlackEnergy's role was still being evaluated [1]. ATT&CK maps BlackEnergy into campaign C0028 [19]; read that mapping as presence and credential theft, not as the cause of the blackout. Greenberg's narrative gives BlackEnergy a more direct role than CISA does [62] [1] (**Inferred** from comparing the two).

Part 4: the 2016 Kyiv transmission attack

4.1 The intrusion

The indictment says a Ukrainian transmission company had been compromised since about April 2016 [5]. Dragos's Joe Slowik places the earliest possible intrusion at a phishing campaign as early as January 2016, with IT entrenchment no later than October [9] (**Confirmed**). On 1 December 2016 at 01:28 two new accounts were created and privileged on the initial ICS access server, and event logging was disabled at 01:29, a timing that implies scripting [9] (**Confirmed**; the log time zone is unspecified).

From about 13:00 on 12 December the operators used Windows Server 2003 MS-SQL servers as pivots, running commands through the xp_cmdshell stored procedure. They made rapid RPC authentication attempts as Administrator with one password across more than 100 hosts [9] (**Confirmed**). Dragos describes the MS-SQL servers as the bridge from business to ICS networks [13]. The operators lived off the land: net use, netstat, files moved as .txt and renamed .exe, PsExec renamed ps.exe, VBS and BAT scripts including remote.vbs for WMI survey and execution, a proxy-aware PowerShell download cradle, and Mimikatz compiled from public source and UPX-packed [9] (**Confirmed**). Slowik observed no other malware apart from the final payloads [9].

4.2 Industroyer

ESET's analysis lists the components: a main backdoor, an additional backdoor in a trojanized Notepad, a launcher, payload DLLs for IEC 60870-5-101, IEC 60870-5-104, IEC 61850 and OPC DA, a data wiper, a custom port scanner and a Siemens SIPROTEC denial-of-service tool [11] (**Confirmed**). The backdoor reached command and control through a hard-coded internal proxy, most C2 servers ran Tor, it could be set to run only at a chosen hour, and it became a service by replacing a non-critical service's ImagePath [11]. US-CERT described it as an extensible ICS attack platform and found no evidence it had affected US infrastructure [10] (**Confirmed**).

The payloads spoke each protocol natively. The IEC 101 payload killed the legitimate serial process, held the COM ports and switched information object addresses off, on, then off. The IEC 104 payload looped select-and-execute commands. The 61850 payload found devices on TCP 102 and flipped switch logical nodes over MMS, and the OPC DA payload wrote items suggesting ABB products [11] (**Confirmed**). CISA notes that the malware abuses the lack of authentication and authorization in these protocols [10].

4.3 The execution

The framework was pushed to target hosts about 16 December. On 17 December BAT files (101_copy.bat, 104_copy.bat) copied payloads, configs and the wiper haslo.dat, and the payloads ran as services configured through the service control tool from remote.vbs [9] (**Confirmed**). Launcher samples carry activation dates of 17 and 20 December; the payloads export a function named Crash, and the wiper starts one or two hours later [11]. Slowik gives trigger times of 22:27 UTC on 17 December and 06:30 UTC on 20 December [9] (**Confirmed**). A hybrid imapi.dll combining OPC and 61850 functions was timed for the second date and compiled before the first outage [9] (**Confirmed** for the artifact). Slowik's suggestion that it aimed to defeat switchgear interlocks is his hypothesis [9] (**Reported**).

The wiper blanked every service ImagePath under `HKLM\SYSTEM\CurrentControlSet\Services`, overwrote files by extension including ICS formats, then killed processes to crash the host [11] (**Confirmed**). The indictment says it deleted files with extensions specific to the victim's ICS brand [5].

4.4 Effect against intent

The direct effect was a relatively brief blackout at one Kyiv substation, modest relative to the malware's capability [9] (**Confirmed**). The UK government says the attack cut power to a fifth of Kyiv for an hour [47]. The SIPROTEC tool exploited CVE-2015-5374 with an 18-byte UDP packet to port 50000 [11] [12]. Slowik found it failed to convert IP byte order and sent its traffic to the wrong addresses, so as built it was effectively useless [9] (**Confirmed**). Greenberg reports Slowik's 2019 reassessment that the attack was built to cause physical damage when lines were re-energised [68] (**Reported**; the Dragos PDFs returned 404). This study therefore presents the protection-related ATT&CK mappings (T0800, T0837, T1499.004) as capability, not confirmed effect.

ESET saw a similarity of concept between the Industroyer wiper and the 2015 wiper, but no code link to BlackEnergy [4] (**Confirmed**). The Industroyer lineage is compared with Stuxnet in Stuxnet: The Case Study.

Part 5: NotPetya and Bad Rabbit (2017)

5.1 The M.E.Doc backdoor

Talos found a backdoor added to `IsNewUpdate` in ZvitPublishedObjects.dll of M.E.Doc, an accounting package that Talos says 80 percent of Ukrainian businesses used [20] (**Confirmed**). Backdoored builds 10.01.175-176, 10.01.180-181 and 10.01.188-189 were released. The backdoor collected EDRPOU company codes, names, proxy and SMTP settings and could download and run code [20]. Talos found a web shell on the server timestamped 31 May 2017 [20]. ESET found a PHP backdoor, medoc_online.php, in an M.E.Doc FTP directory, and noted that the XData ransomware, seen on 18 May 2017, also used M.E.Doc as its vector [21] (**Confirmed**). ATT&CK records Sandworm's research into EDRPOU identifiers before the attack [14].

On 27 June 2017 stolen admin credentials were used to reconfigure NGINX so that upd.me-doc.com.ua proxied to 176.31.182.167; the configuration was restored around 12:33 UTC [20] (**Confirmed**). The indictment alleges a delivery window of about 12:14 to 15:31 Moscow time and a France-based server, with a cookie that carried the victim's EDRPOU list [5] (**Confirmed** as charged). Talos assessed the intent as destructive, not financial [20]. Mandiant notes the timing on Ukraine's Constitution Day [60].

5.2 The worm

Microsoft observed the M.E.Doc updater EzVit.exe running the malicious command line. NotPetya used token impersonation, copied itself to admin$ and ran with PsExec or WMIC, exploited CVE-2017-0144 and CVE-2017-0145, and scanned tcp/139 and tcp/445 [22] (**Confirmed**). It overwrote the first 10 sectors of the disk, scheduled a forced restart through shutdown.exe, and cleared the System, Setup, Security and Application logs and the NTFS journal [22]. CISA found modified Mimikatz with stolen credentials was the first and usually most effective propagation method, with EternalBlue and EternalRomance (MS17-010, patched 14 March 2017) as the alternative [23] (**Confirmed**). The indictment adds that it checked for antivirus processes and fell back to the exploits only if both credential methods failed [5]. CISA judged it to behave more like destructive malware than ransomware, with recovery unlikely [23], and the indictment calls the $300 bitcoin ransom a ruse [5] (**Confirmed**). Talos documented the same toolkit [69], and in the book Talos's Craig Williams calls it the fastest-propagating malware Talos had seen [31] (**Reported**).

ESET attributed NotPetya (Diskcoder.C) to TeleBots [21], and in October 2018 presented the Exaramel backdoor as code evidence linking Industroyer to TeleBots and through them to NotPetya [35] (**Confirmed** as

a vendor assessment).

5.3 The losses in the filings

Victim	What the primary record says	Source	Grade
Heritage Valley Health System	Two hospitals, 60 physician offices and 18 satellite facilities; mission-critical systems down about a week, administrative systems almost a month; more than $2 million	[5]	Confirmed (charged)
FedEx (TNT Express)	About $300 million ($0.79 per share) in the quarter to 31 August 2017; no cyber insurance covering it [27]; about $400 million ($1.19 per share) in the first half of FY2018 [28]	[27] [28]	Confirmed
Merck	About $260 million lower 2017 sales; about $285 million costs net of about $45 million insurance recoveries; Gardasil 9 doses borrowed from the CDC stockpile [25]; 2018 sales effect about $150 million and disputes with insurers [26]	[25] [26]	Confirmed
Mondelez	Significant portion of global sales, distribution and financial networks hit; 0.4 percent off net revenue growth; $84 million incremental expenses [29]; $37 million net recoveries recorded in 2022 [30]	[29] [30]	Confirmed
Three named victims together	Nearly $1 billion in losses	[5]	Confirmed (charged)

Linking the Mondelez 2022 recoveries to its insurance litigation is reasoning only; the litigation record was not opened [30] (**Inferred**).

The book's figures are larger and cover more victims. Greenberg's table gives Merck $870 million, FedEx $400 million, Saint-Gobain $384 million, Maersk $300 million, Mondelez $188 million and Reckitt Benckiser $129 million, with a White House assessment of more than $10 billion that Tom Bossert confirmed to WIRED [31] (**Reported**). The White House statement itself says "billions of dollars" and gives no total [32] (**Confirmed**). Speaking at Davos, Snabe put Maersk's cost at $250 million to $300 million; 4,000 servers and 45,000 PCs were rebuilt in about 10 days; 17 of 76 terminals were affected; and recovery hinged on one surviving domain controller in Ghana [31] (**Reported**; Maersk's own filings could not be opened).

5.4 Attribution

The White House attributed NotPetya to the Russian military on 15 February 2018 and called it the most destructive and costly cyber attack in history [32] (**Confirmed**). The UK said the same day that the Russian military was responsible, with costs of hundreds of millions of pounds [33] (**Confirmed**). The indictment alleges that Andrienko, Detistov, Frolov and Pliskin developed NotPetya components [5].

5.5 Bad Rabbit

On 24 October 2017 Bad Rabbit (Diskcoder.D, a modified Diskcoder.C) spread from hacked media sites through injected JavaScript that offered a fake Flash update [36] [37] (**Confirmed**). The user had to launch the dropper. It scanned SMB shares, used Mimikatz and an NTLM brute force with a hardcoded list, and ran infpub.dat through SCManager and rundll32 [36] [37]. It encrypted with DiskCryptor-derived code and set a scheduled task [37]. ESET first saw no EternalBlue and updated on 27 October that EternalRomance may have been used [36]; Kaspersky reports EternalRomance [37]. ESET's dropper telemetry was 65 percent Russia, 12.2 percent Ukraine, 10.2 percent Bulgaria, 6.4 percent Turkey and 3.8 percent Japan [36]. Kaspersky counted almost 200 targets and judged it not intended as a wiper [37] (**Confirmed**). US-CERT advised victims not to pay [38].

The UK attributed Bad Rabbit to the GRU on 4 October 2018 and listed the Kyiv metro, Odessa airport, Russia's central bank and two Russian media outlets among its victims [34] (**Confirmed**). Bad Rabbit does not appear in the 2020 indictment [5] (**Confirmed** by text search), and the book's Bad Rabbit chapter was not checked.

Part 6: Olympic Destroyer, VPNFilter and Georgia (2018 to 2019)

6.1 PyeongChang

The indictment alleges that preparation began on or about 4 December 2017, the day before the IOC suspended the Russian Olympic Committee [5] (**Confirmed** as charged). From December 2017 to February 2018 the conspirators spearphished Olympic partners, the IOC and Korean agencies through spoofed domains, and built malicious mobile apps; one, Hmail-App, had 47 installs [5]. Kaspersky found macro-laden Office documents first seen in December 2017 that ran a PowerShell scriptlet, including one email spoofing a South Korean counter-terrorism address [40]. IT Company 2 was compromised by 19 December and IT Company 1 by 21 December. On 12 January 2018 the conspirators took a domain administration account, and on 23 and 24 January PowerShell scripts dumped credentials from more than 16,000 IT Company 1 computers and servers [5] (**Confirmed** as charged). Kaspersky puts the attackers inside a PyeongChang hotel network by 6 February [40].

At about 7:42 p.m. KST on 9 February 2018, during the opening ceremony, a "Deployer Account" pushed the wiper across IT Company 1's domain; thousands of computers were compromised and 30 Organizing Committee computers were wiped [5] (**Confirmed** as charged). The wiper misconfigured BitLocker so laptops rebooted asking for a recovery key [5]. Talos named Olympic Destroyer on 12 February. It stole browser and LSASS credentials, found targets through the ARP table and WMI, spread with PsExec and WMI, and deleted shadow copies and the backup catalog [39]. It also disabled recovery with bcdedit, cleared logs with wevtutil, overwrote files on mapped shares and shut down [39] (**Confirmed**). One binary held 44 accounts, and the list was updated after each theft [39]. Ski gates and lifts at one resort were disabled [40]. In the book all nine of the organizing committee's domain controllers were paralysed [71] (**Reported**).

6.2 The false flag

Kaspersky found the Rich header of a wiper sample was forged to match Lazarus components and did not match the code [40] (**Confirmed**). Kaspersky also noted hosting habits like Sofacy's without attributing [40]. The indictment states the code was written to emulate Lazarus Group malware [5] (**Confirmed**). Greenberg's account follows other false trails, including Intezer's links to APT3 and APT10. It also follows FireEye analyst Michael Matonis's link from lure documents to a domain in an FBI flash about 2016 election-board intrusions [71] (**Reported**; Matonis's work and the FBI flash have no public primary). Mandiant later put the Olympics attack on APT44 as a response to the doping ban [60]. The same actor returned in May and June 2018 with Spiez Laboratory and Salisbury-themed lures against Russian financial organizations and chemical and biological threat-prevention labs [41] (**Confirmed**).

6.3 VPNFilter

On 23 May 2018 Talos estimated at least 500,000 VPNFilter infections in at least 54 countries, on Linksys, MikroTik, NETGEAR and TP-Link routers and QNAP NAS devices [42] (**Confirmed**). Stage 1 survived reboot and found stage 2 through GPS data hidden in Photobucket images, falling back to a domain or a trigger-packet listener [42]. Stage 2 had a kill command that overwrote flash and rebooted, bricking the device, and stage 3 plugins sniffed traffic including Modbus TCP and talked over Tor [42]. Talos saw an RC4 implementation overlapping BlackEnergy ("not definitive") and infection spikes in Ukraine on 8 and 17 May [42]. The June update added ASUS, D-Link, Huawei, Ubiquiti, UPVEL and ZTE, the ssler man-in-the-middle module and the dstr wiper [43] (**Confirmed**). The FBI asked owners to reboot their routers and named only foreign cyber actors [44].

Attribution moved over time. SentinelLabs states that the 2018 DOJ action named APT28/Sofacy [45] (**Reported**; the 2018 DOJ release could not be opened). The NCSC said in 2022 that the DOJ had linked VPNFilter to Sandworm, and ATT&CK lists VPNFilter (S1010) under G0034 [46] [14] (**Confirmed**).

6.4 Georgia

On 31 July and 1 August 2019 Ochichenko ran technical reconnaissance of the Parliament of Georgia's domain and tried to gain network access [5] (**Confirmed**). On 28 October 2019 the conspirators compromised a Georgian web hosting provider, defaced about 15,000 websites and disrupted some, many showing a former president captioned "I'll be back." [5] (**Confirmed**). The UK judged the GRU "almost certainly (95%+)" responsible, noting that several web hosting providers were hit and several national broadcasters interrupted [47]. The State Department said at least two TV stations' broadcasts were interrupted [72] (**Confirmed**). The book's first edition appeared on 5 November 2019, eight days later, and cannot cover it in depth [61] (**Inferred**).

Part 7: the 2022 war operations and after

7.1 Sorting the wipers

Not every wiper of early 2022 belongs to Sandworm. Microsoft tracks WhisperGate (first seen 13 January) to DEV-0586, now Cadet Blizzard, distinct from Sandworm [51] (**Confirmed**). HermeticWiper started around 14:52 UTC on 23 February, abused signed EaseUS drivers, carried a Hermetica Digital certificate revoked on 24 February, and in one case was pushed through the default domain GPO alongside the HermeticWizard worm and HermeticRansom; IsaacWiper followed from 24 to 26 February [52] (**Confirmed**). ESET could not attribute any of them [52], and the library's ATT&CK data links HermeticWiper (S0697) and HermeticWizard (S0698) to no group [87]. CaddyWiper appeared on 14 March on several dozen systems and ESET named no actor [53]; ATT&CK places later CaddyWiper use in C0034 [75]. By April Microsoft counted more than 237 operations by at least six Russia-aligned actors against Ukraine, close to 40 of them destructive, naming IRIDIUM among them [56] (**Confirmed**).

7.2 Cyclops Blink and AcidRain

On 23 February 2022 the NCSC, CISA, NSA and FBI described Cyclops Blink as a VPNFilter replacement deployed since at least June 2019 on WatchGuard devices exposed for remote management. It persisted through firmware updates and ran C2 over TLS managed through Tor, and the agencies attributed it to Sandworm [48] (**Confirmed**). The NCSC's analysis describes a 32-bit PowerPC ELF with four modules, persisting through a modified S51armled RC script [49]. Trend Micro found an ARM variant for ASUS routers, more than 150 C2 servers and about 200 victims [50] (**Confirmed**).

The UK says Russia was almost certainly behind the Viasat KA-SAT attack about an hour before the 24 February invasion, without naming Sandworm [59] (**Confirmed**). SentinelLabs found the AcidRain modem wiper and rated its similarity to VPNFilter's dstr module at medium confidence; about 5,800 Enercon wind turbines lost remote monitoring [45] (**Confirmed**). ATT&CK lists AcidRain (S1125) under G0034 [14].

7.3 Industroyer2

ESET, working with CERT-UA, attributes Industroyer2 to Sandworm with high confidence. It was set to run at 16:10 UTC on 8 April 2022 against high-voltage substations, using only IEC-104, alongside CaddyWiper and the Linux and Solaris wipers ORCSHRED, SOLOSHRED and AWFULSHRED [54] (**Confirmed**). CERT-UA's alert #4435 dates initial compromise to no later than February 2022 and the Industroyer2 build to 23 March, with per-substation parameters [55]. It describes CaddyWiper loaded by ARGUEPATCH and TAILJUMP and pushed by GPO through POWERGAP, SSH tunnel chains, Impacket and two waves [55]. CERT-UA says the attack was prevented and attributes it to UAC-0082, Sandworm [55] (**Confirmed**; the alert is in Ukrainian and was read through the site's article API).

7.4 The October 2022 outage

Mandiant reports that Sandworm had access by June 2022 through a Neo-REGEORG web shell and the GOGETTER tunneler [58]. On 10 October it mounted an ISO image on a MicroSCADA hypervisor and ran the vendor's own scilc.exe, likely sending breaker-open commands, which caused a power outage. On 12 October it wiped IT systems with a new CaddyWiper pushed through GPO [58] (**Confirmed**). Mandiant does not assert a link to the missile strikes that coincided with it [58]. ATT&CK records this as campaign C0034 [75]. A day later, on 11 October, Prestige ransomware hit transportation and logistics organizations in Ukraine and Poland. It was deployed through ADMIN$ and an Impacket scheduled task, encoded PowerShell or the default domain GPO, and Microsoft assessed IRIDIUM "very likely" responsible [57] (**Confirmed**).

7.5 After 2022

Mandiant's APT44 report describes a shift from disruption toward intelligence collection in the war's second year and says APT44 is responsible for nearly all disruptive operations against Ukraine in the past decade [60] (**Confirmed**). ATT&CK's 2025 Poland Wiper Attacks campaign (C0063) carries split attribution, with some reporting pointing to the FSB-linked Dragonfly (G0035) and other reporting to ELECTRUM/Sandworm [76] (**Confirmed**). This study does not assign C0063 to Sandworm. The 2024 to 2026 record, including the Poland attack and the evidence on each side of its attribution, is told in Industrial Control System Attacks and Advisories, 2024 to 2026.

Part 8: exploited vulnerabilities

CVE	Product	Use in the record	NVD CWE	CISA KEV	Sources
CVE-2014-4114	Microsoft Windows, delivered in Office documents	Exploited in the wild in a Sandworm campaign, 2014; cited on G0034's T1203 row	NVD-CWE-noinfo	Added 2022-03-03; ransomware use Unknown	[63] [64] [65] [14]
CVE-2013-3906	not checked	Cited on G0034's T1203 row; NVD not opened for this study	not checked	not checked	[14]
CVE-2014-0751	GE CIMPLICITY HMI	Probable vector in the BlackEnergy HMI campaign, exploited from at least January 2012	CWE-22	Not in KEV	[8] [66] [65]
CVE-2015-5374	Siemens SIPROTEC EN100	Industroyer DoS tool, 2016 (failed as built); published 2015-07-18	CWE-19 (a broad category id)	Not in KEV	[11] [12] [9] [65]
CVE-2017-0144	Microsoft SMBv1 (EternalBlue)	NotPetya, 2017	NVD-CWE-noinfo	Added 2022-02-10; ransomware use Known	[22] [23] [24] [65]
CVE-2017-0145	Microsoft SMBv1 (EternalRomance)	NotPetya and Bad Rabbit, 2017	NVD-CWE-noinfo	Added 2022-02-10	[22] [23] [24] [37]

Most of this record ran on credentials, native tools and legitimate software, not on exploits. In 2015 no exploit code was found [2], in 2016 the operators used native commands and credential re-use [9], and in 2022 they

ran the vendor's own SCADA binary [58] (**Inferred** from these sources).

This study did not open the NSA's 2020 advisory on Sandworm's exploitation of Exim mail servers (CVE-2019-10149), so that CVE is not in the table; The Year 2019 in Intrusions: A Dated Record and The Year 2020 in Intrusions: A Dated Record cite it.

Part 9: the government and legal record

9.1 The indictment

The indictment was filed on 15 October 2020 in the Western District of Pennsylvania (Criminal No. 20-316) [5] (**Confirmed**). It has seven counts:

1. Conspiracy under 18 U.S.C. 371, with computer-fraud objects under 1030(a)(2)(C) and (a)(5)(A) and the 3559(g)(1) enhancement.
2. Wire fraud conspiracy under 18 U.S.C. 1349.
3. and 4. Wire fraud under 1343 against Heritage Valley Health System on 27 June 2017.
5. Damage to protected computers under 1030(a)(5)(A) and (c)(4)(B) at Heritage Valley.
6. and 7. Aggravated identity theft under 1028A, using IT Company 1 accounts in January 2018.

Forfeiture is sought under 18 U.S.C. 982 and 1030(i) [5]. The charged conduct covers the 2015 and 2016 grid attacks, the Ministry of Finance and State Treasury attack, the 2017 French presidential campaign, NotPetya, PyeongChang, the OPCW and DSTL spearphishing, and Georgia [5] (**Confirmed**). Charges are allegations; the defendants are presumed innocent.

9.2 Government statements

Date	Government	What it said	Source
15 Feb 2018	United States (White House)	NotPetya was the Russian military's work, part of the Kremlin's effort to destabilize Ukraine	[32]
15 Feb 2018	United Kingdom (FCO, NCSC)	Russian military almost certainly responsible for NotPetya	[33]
4 Oct 2018	United Kingdom	GRU almost certainly behind Bad Rabbit; restates NotPetya	[34]
20 Feb 2020	United Kingdom	GRU GTsST almost certainly (95%+) behind Georgia; recalls the 2015 and 2016 blackouts	[47]
20 Feb 2020	United States (State Department)	GTsST, Unit 74455, Sandworm behind Georgia	[72]
15 Oct 2020	United States (DOJ)	Indictment of six officers	[5]
20 Jul 2021	United States (CISA)	Notes added to the 2014, 2016 and 2017 ICS alerts attributing the activity to Russian nation-state actors	[1] [8] [10]
23 Feb 2022	UK and US agencies	Cyclops Blink attributed to Sandworm	[48]
2022	United Kingdom	Russia almost certainly behind the Viasat attack	[59]

CISA's 2022 advisory AA22-110A on Russian threats to critical infrastructure lists patching among its immediate actions [84] (**Confirmed**).

Part 10: the book against the record

Greenberg's *Sandworm* was published by Doubleday on 5 November 2019, with a Vintage paperback on 20 October 2020 [61] (**Confirmed**). The library's book list gives "2019/2022"; a 2022 edition was not checked, so this study cites the 2019 and 2020 editions only. The book's text was read through three WIRED excerpts [62] [31] [71]; its chapters on VPNFilter, Bad Rabbit and WannaCry were not checked.

Book claim (via WIRED excerpt)	What the primary record says	Verdict
FireEye's team spotted and named Sandworm in 2014 [62]	MS14-060 credits iSIGHT Partners and ESET [63]	MS14-060 credits iSIGHT Partners, not FireEye (**Inferred** reading)
Nearly a quarter-million Ukrainians lost power in 2015 [62]	About 225,000 customers [1] [2]	Consistent; use the primary figure
Phantom mouse, flooded call centers, firmware and backup power sabotage [62]	Remote operators, telephone DoS, converter firmware and UPS disconnects [1] [2]	Confirmed in substance
BlackEnergy as the attack tool [62]	BlackEnergy's role still being evaluated; the outage was interactive [1] [2]	The primaries are more cautious

Book claim (via WIRED excerpt)	What the primary record says	Verdict
Kyiv station down just before midnight on 16 December 2016 local time [68]	17 December per ESET [4]; trigger 22:27 UTC on 17 December per Slowik [9]	Dates differ by clock and source; this study uses 17 December
Siprotec relay attack built for physical damage but sent to wrong IPs [68]	Byte-order bug made the tool useless [9]	Confirmed for the bug; the damage intent stays Reported
GRU hijacked M.E.Doc updates in spring 2017 [31]	Backdoored builds from 14 April 2017 [20] [23]; GRU attribution [32] [33] [5]	Confirmed
More than $10 billion in damage [31]	White House says "billions" with no total [32]	Reported only
Maersk saved by one domain controller in Ghana [31]	No primary opened	Reported only
Olympics attack was GRU Unit 74455, not North Korea [71]	Indictment names Andrienko, Pliskin, Kovalev and Ochichenko for it [5] [73]	Confirmed

ESET's Exaramel link from Industroyer to NotPetya [35], ANSSI's Centreon report [74], Industroyer2 [54] and the 2022 MicroSCADA outage [58] all extend the record past the book.

Part 11: the defender view

11.1 Identity is the control plane

Every grid attack in this record moved on credentials: probably stolen VPN credentials in 2015 [1] [5], one Administrator password tried across more than 100 hosts in 2016 [9], credential theft as NotPetya's first spread method [23], 16,000 hosts' credentials before PyeongChang [5]. Defenders should watch domain account creation, privilege grants and event-log disablement. The 2016 operators did all three within a minute [9]. This lesson is **Inferred** from the cited sources.

11.2 Segment, and plan to run without the network

CISA's 2016 advice was to isolate ICS from untrusted networks and lock down unused ports and services [1] (**Confirmed**); this study treats it as the baseline (**Inferred**). After Industroyer it added enclaves, removing remote access and modems, monitoring-only access through data diodes, allowlisting on HMIs, and a restoration plan built on gold disks [10] (**Confirmed**). Across the 49 ICS techniques in this record, ATT&CK's most frequent mitigations are Network Segmentation (M0930), Network Allowlists (M0807), Out-of-Band Communications Channel (M0810) and Data Backup (M0953) [86] (Part 13.6).

11.3 Native tools defeat allowlisting

In October 2022 the outage came from the vendor's own scilc.exe launched from a mounted ISO [58]. Application allowlisting alone would not have stopped that. It needs to be paired with disabling autorun and with process-spawn analysis (D3-PSA) on SCADA hosts [58] (**Inferred**). Group Policy deserved the same attention: HermeticWiper [52], CaddyWiper [55] [58] and Prestige [57] were all pushed through it.

11.4 Edge and home-office devices are in scope

VPNFilter reached half a million devices and could brick them [42]. Cyclops Blink persisted through WatchGuard firmware updates [48], and AcidRain wiped satellite modems [45]. A grid operator's attack surface includes the routers and firewalls its staff and suppliers use (**Inferred**). The FBI's first advice was simply to reboot [44]. Cyclops Blink targeted WatchGuard devices exposed for remote management [48], so those interfaces are the place to start (**Inferred**).

11.5 Update channels are privileged code paths

NotPetya rode a trusted vendor's update server [20]. Watch what updaters launch [22], and treat third-party updaters on finance and operations hosts as tier-zero software (**Inferred**).

Part 12: library corrections

The library review for this study found these lags (**Inferred** from the library's text on main as of 3 November 2026, against the sources cited):

- `THREAT_ACTORS.md` lists Olympic Destroyer under APT28, but the indictment and ATT&CK place it with Sandworm [5] [79].
- `MALWARE_FAMILIES.md` attributes HermeticWiper and CaddyWiper wholesale to Sandworm. ESET attributed neither [52] [53], and the library's ATT&CK data links S0697 and S0698 to no group [87]. It also cites APT3 false flags that no opened primary supports, and calls Industroyer2 "partially foiled" where CERT-UA says the attack was prevented [55].
- `NOTABLE_INCIDENTS.md` has no entry for the 2015 or 2016 Ukrainian grid attacks [87].
- `data/attack/software.jsonl` has no entries for ORCSHRED, SOLOSHRED, AWFULSHRED, ARGUEPATCH, TAILJUMP, POWERGAP, GOGETTER, IsaacWiper or HermeticRansom [87] (**Confirmed** as a data check).
- The library's generated G0034 page lists 79 Enterprise techniques against 98 on live ATT&CK. The 19 missing ids reach G0034 through campaigns C0028, C0025 and C0034 [14] [87] (**Confirmed**).

Part 13: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, ATT&CK for ICS, CAPEC, CWE and D3FEND. Every identifier was checked against the live ATT&CK pages [14] [15] [16] [17] [18] [19] [75] [77] [78] [79] [80] [81] [82] [83] or the library's data files [87]. Identifiers that could not be checked are left out. Read ATT&CK's mapping of a technique to a software object as what the tool can do; the dated-event column says where the verified record shows it happening.

13.1 Objects

Object	ATT&CK id	Library page	Relationship
Sandworm Team	G0034	/mitre/groups/G0034.md	The group; v4.2, modified 31 July 2026 [14]
2015 Ukraine Electric Power Attack	C0028	/mitre/campaigns/C0028.md	December 2015 to January 2016 [15]
2016 Ukraine Electric Power Attack	C0025	/mitre/campaigns/C0025.md	December 2016; Industroyer [16]
2022 Ukraine Electric Power Attack	C0034	/mitre/campaigns/C0034.md	June to October 2022; CaddyWiper and Neo-reGeorg [75]
2025 Poland Wiper Attacks	C0063	/mitre/campaigns/C0063.md	Split attribution; not assigned to Sandworm here [76]
BlackEnergy	S0089	/mitre/software/S0089.md	2015 grid [19]
KillDisk	S0607	/mitre/software/S0607.md	2015 grid and 2016 Ministry of Finance [18] [5]
Industroyer	S0604	/mitre/software/S0604.md	2016 Kyiv [17]
NotPetya	S0368	/mitre/software/S0368.md	June 2017 [78]
Bad Rabbit	S0606	/mitre/software/S0606.md	October 2017 [81]
Olympic Destroyer	S0365	/mitre/software/S0365.md	February 2018 [79]
VPNFilter	S1010	/mitre/software/S1010.md	2018 [80]
Exaramel for Windows	S0343	/mitre/software/S0343.md	ESET's Industroyer to TeleBots link [35]
Exaramel for Linux	S0401	/mitre/software/S0401.md	Same report [35]
P.A.S. Webshell	S0598	/mitre/software/S0598.md	ANSSI Centreon campaign [74]
Cyclops Blink	S0687	/mitre/software/S0687.md	Since June 2019 [83]
CaddyWiper	S0693	/mitre/software/S0693.md	2022 [82]
Industroyer2	S1072	/mitre/software/S1072.md	April 2022 [77]
Prestige	S1058	/mitre/software/S1058.md	October 2022; associated with G0034 [14] [57]
AcidRain	S1125	/mitre/software/S1125.md	February 2022; associated with G0034 [14] [45]
HermeticWiper	S0697	/mitre/software/S0697.md	Linked to no group in the library's ATT&CK data; not attributed here [52] [87]
HermeticWizard	S0698	/mitre/software/S0698.md	Linked to no group in the library's ATT&CK data; not attributed here [52] [87]
Mimikatz	S0002	/mitre/software/S0002.md	2016, NotPetya, Bad Rabbit [9] [23] [36]

Object	ATT&CK id	Library page	Relationship
PsExec	S0029	/mitre/software/S0029.md	2016, NotPetya, Olympic Destroyer [9] [22] [39]
Dragonfly	G0035	/mitre/groups/G0035.md	Named in C0063's split attribution only [76]

The Mobile entry CHEMISTGAMES (S0555) on live G0034 has no library page and is not bound here [87].

13.2 ATT&CK Enterprise techniques (78)

Each row is a technique that ATT&CK v20.0 lists on G0034, its campaigns or its software and that the verified record ties to a dated event. The one exception is T1134.001, which this study maps from Microsoft's NotPetya analysis [22]. Tactics come from the library's data/attack/technique_profiles.jsonl [87]. Two revoked ids appear in older write-ups: T1070.001 is now T1685.005 and T1562.004 is now T1686, per data/attack/superseded_by.jsonl [87]. Cyclops Blink's firmware persistence is T1542.002 on ATT&CK, where AA22-054A lists T1542.001 [83] [48].

ID	Name	Tactic(s)	Dated event or report	Sources
T1566.001	Phishing: Spearphishing Attachment	Initial Access	2015 grid: macro-enabled Excel and Word attachments carrying BlackEnergy 3, from spring 2015; PyeongChang lures, Dec 2017	[2] [5] [15] [40]
T1204.002	User Execution: Malicious File	Execution	2015 grid: victims enabled the macros; Bad Rabbit fake Flash installer, 2017-10-24	[2] [15] [36] [37] [81]
T1059.005	Command and Scripting Interpreter: Visual Basic	Execution	2015 lure macro (metadata 2015-07-27); remote.vbs and other VBS in Dec 2016	[6] [15] [9] [16]
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Execution	Dec 2016: xp_cmdshell on MS-SQL pivots; 101_copy.bat and 104_copy.bat	[9] [16]
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	Dec 2016: proxy-aware PowerShell download cradle	[9] [16]
T1218.011	System Binary Proxy Execution: Rundll32	Stealth	BlackEnergy lure runs FONTCACHE.DAT with rundll32 (2015); NotPetya and Bad Rabbit install via rundll32 (2017)	[6] [15] [78] [36] [81]
T1071.001	Application Layer Protocol: Web Protocols	Command and Control	BlackEnergy HTTP POST command and control, 2015	[6] [15] [19]
T1056.001	Input Capture: Keylogging	Collection, Credential Access	2015 grid: BlackEnergy keylogger plugin gathered credentials	[15] [19]
T1040	Network Sniffing	Credential Access, Discovery	2015 grid: BlackEnergy network sniffer module captured credentials	[15]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	2015 grid: previously obtained legitimate credentials used over VPN	[1] [15]

ID	Name	Tactic(s)	Dated event or report	Sources
T1136.002	Create Account: Domain Account	Persistence	2015 grid: privileged domain accounts; 2016-12-01 01:28 two new accounts created and privileged	[15] [9] [16]
T1133	External Remote Services	Persistence, Initial Access	2015 grid: VPNs from the business network into the ICS, apparently without two-factor authentication	[1] [2] [15]
T1018	Remote System Discovery	Discovery	2015 grid: systems discovered over the LAN; Olympic Destroyer used the ARP table and WMI (2018)	[15] [39] [79]
T1105	Ingress Tool Transfer	Command and Control	2015 grid tool transfer; Dec 2016 PowerShell download cradle	[15] [9]
T1570	Lateral Tool Transfer	Lateral Movement	2015 grid; Dec 2016 files moved as .txt and renamed .exe, payloads copied by BAT files on 2016-12-17	[15] [9] [16]
T1055	Process Injection	Stealth, Privilege Escalation	2015 grid: BlackEnergy loaded into svchost.exe	[15]
T1112	Modify Registry	Defense Impairment, Persistence	2015 grid: registry Internet settings lowered before rundll32 ran	[15]
T1685	Disable or Modify Tools	Defense Impairment	2015 grid: Internet security settings lowered in the registry	[15]
T1070.004	Indicator Removal: File Deletion	Stealth	2015 grid: KillDisk deleted files and logs	[1] [5] [15] [18]
T1110	Brute Force	Credential Access	2016-12-12 onward: rapid RPC authentication attempts as Administrator across more than 100 hosts	[9] [16]
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	Mimikatz in Dec 2016; NotPetya's modified Mimikatz (2017-06-27); Olympic Destroyer LSASS theft (2018-02-09)	[9] [16] [23] [78] [39] [79]
T1027.002	Software Packing	Stealth	Dec 2016: Mimikatz compiled from public source and UPX-packed	[9] [16]
T1098	Account Manipulation	Persistence, Privilege Escalation	Dec 2016: sp_addlinkedsrvlogin linked a created account to other MS-SQL servers	[16]
T1036.010	Masquerade Account Name	Stealth	2016-12-01: new accounts named to look like system accounts	[16]
T1685.001	Disable or Modify Windows Event Log	Defense Impairment	2016-12-01 01:29: event logging disabled on the ICS access server	[9] [16]
T1505.001	Server Software Component: SQL Stored Procedures	Persistence	From 2016-12-12: MS-SQL servers used as pivots via xp_cmdshell	[9] [16]
T1047	Windows Management Instrumentation	Execution	remote.vbs WMI execution (Dec 2016); NotPetya WMIC (2017); Olympic Destroyer WMI spread (2018)	[9] [16] [22] [23] [78] [39] [79]

ID	Name	Tactic(s)	Dated event or report	Sources
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	Dec 2016; NotPetya copy to admin$ (2017); Olympic Destroyer (2018)	[16] [22] [78] [79]
T1036.008	Masquerade File Type	Stealth	Dec 2016: executables moved as .txt files and renamed	[9] [16]
T1036.005	Match Legitimate Resource Name or Location	Stealth	PsExec renamed ps.exe (Dec 2016); Bad Rabbit install_flash_player.exe (2017)	[9] [16] [36] [81]
T1543.003	Create or Modify System Process: Windows Service	Persistence, Privilege Escalation	Industroyer backdoor made a service by replacing a non-critical service's ImagePath; payloads run as services, 2016-12-17	[11] [17] [9]
T1554	Compromise Host Software Binary	Persistence	Industroyer additional backdoor: a trojanized Notepad, 2016	[11] [17]
T1046	Network Service Discovery	Discovery	Industroyer custom port scanner (2016); NotPetya scanned tcp/139 and tcp/445 (2017)	[11] [17] [22]
T1016	System Network Configuration Discovery	Discovery	Industroyer network configuration discovery, 2016	[17]
T1082	System Information Discovery	Discovery	Industroyer system information discovery, 2016	[17]
T1083	File and Directory Discovery	Discovery	Industroyer file discovery, 2016	[17]
T1012	Query Registry	Discovery	Industroyer registry queries, 2016	[17]
T1572	Protocol Tunneling	Command and Control	Industroyer HTTP CONNECT tunnel via an internal proxy (2016); GOGETTER TLS tunnel (2022); SSH tunnel chains (April 2022)	[11] [17] [75] [55]
T1090.003	Proxy: Multi-hop Proxy	Command and Control	Industroyer C2 servers mostly ran Tor, 2016	[11] [17]
T1140	Deobfuscate/Decode Files or Information	Stealth	Industroyer decoding, 2016	[17]
T1041	Exfiltration Over C2 Channel	Exfiltration	Industroyer exfiltration over C2, 2016	[17]
T1485	Data Destruction	Impact	Industroyer wiper (Dec 2016); KillDisk (2015); Olympic Destroyer (2018); CaddyWiper (2022)	[11] [17] [18] [79] [53] [58] [82]
T1489	Service Stop	Impact	KillDisk kills komut.exe and sec_service.exe (2015); Industroyer wiper kills processes (2016)	[7] [18] [11] [17]
T1499.004	Endpoint Denial of Service: Application or System Exploitation	Impact	Industroyer SIPROTEC DoS tool for CVE-2015-5374 (capability; Slowik found it failed as built)	[11] [12] [17] [9]
T1685.005	Disable or Modify Tools: Clear Windows Event Logs	Defense Impairment	KillDisk clears Application, Security, Setup and System logs (2015); NotPetya (2017); Olympic Destroyer wevtutil (2018)	[7] [18] [22] [39] [79]

ID	Name	Tactic(s)	Dated event or report	Sources
T1561.002	Disk Wipe: Disk Structure Wipe	Impact	KillDisk corrupted MBRs (2015); NotPetya overwrote the first 10 sectors (2017); CaddyWiper (2022)	[1] [18] [22] [23] [82]
T1529	System Shutdown/Reboot	Impact	KillDisk rebooted hosts (2015); NotPetya forced restart through shutdown.exe (2017)	[5] [18] [22] [78]
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	Persistence, Privilege Escalation	BlackEnergy lure adds a Startup-folder shortcut (2015-07-27 sample)	[6] [19]
T1195.002	Compromise Software Supply Chain	Initial Access	Backdoored M.E.Doc updates 2017-04-14 to 2017-06-22; NotPetya delivered 2017-06-27	[20] [21] [23] [5]
T1134.001	Access Token Manipulation: Token Impersonation/Theft	Stealth, Privilege Escalation	NotPetya token impersonation, 2017-06-27 (this study's mapping from the Microsoft analysis; not an ATT&CK row on S0368)	[22]
T1569.002	System Services: Service Execution	Execution	NotPetya via PsExec (2017-06-27); Bad Rabbit via SCManager (2017-10-24)	[22] [23] [78] [36] [81]
T1210	Exploitation of Remote Services	Lateral Movement	NotPetya EternalBlue and EternalRomance (2017); Bad Rabbit EternalRomance (2017)	[22] [23] [78] [37] [81]
T1518.001	Software Discovery: Security Software Discovery	Discovery	NotPetya checked for antivirus processes, 2017	[5] [78]
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	NotPetya scheduled forced restart (2017); Bad Rabbit scheduled task (2017); Prestige via Impacket scheduled task (2022-10-11)	[22] [78] [37] [81] [57]
T1486	Data Encrypted for Impact	Impact	NotPetya encrypted the MFT (2017); Bad Rabbit DiskCryptor (2017); Prestige (2022)	[23] [78] [36] [81] [57]
T1189	Drive-by Compromise	Initial Access	Bad Rabbit watering hole with injected JavaScript, 2017-10-24	[36] [37] [81]
T1110.003	Brute Force: Password Spraying	Credential Access	Bad Rabbit NTLM brute force with a hardcoded list, 2017-10-24	[37] [81]
T1135	Network Share Discovery	Discovery	Bad Rabbit SMB share scanning (2017); Olympic Destroyer mapped shares (2018)	[36] [81] [39] [79]
T1593	Search Open Websites/Domains	Reconnaissance	Research into Ukraine's EDRPOU identifiers before NotPetya, 2017	[14] [20]
T1591.002	Gather Victim Org Information: Business Relationships	Reconnaissance	Research into PyeongChang partner organizations, Dec 2017	[14] [5]
T1588.006	Obtain Capabilities: Vulnerabilities	Resource Development	2017 vulnerability research on Olympic-related websites	[14]

ID	Name	Tactic(s)	Dated event or report	Sources
T1490	Inhibit System Recovery	Impact	Olympic Destroyer: vssadmin, wbadmin and bcdedit, 2018-02-09	[39] [79]
T1561.001	Disk Wipe: Disk Content Wipe	Impact	VPNFilter kill command and dstr module wipe device flash, May and June 2018	[42] [43] [80]
T1491.002	Defacement: External Defacement	Impact	About 15,000 Georgian websites defaced, 2019-10-28	[5] [47] [14]
T1499	Endpoint Denial of Service	Impact	Georgian websites disrupted after a hosting provider was compromised, 2019-10-28	[5] [14]
T1590.001	Gather Victim Network Information: Domain Properties	Reconnaissance	Reconnaissance of the Parliament of Georgia domain, 2019-07-31 and 2019-08-01	[5] [14]
T1542.002	Pre-OS Boot: Component Firmware	Stealth, Persistence	Cyclops Blink persists through firmware update, deployed since at least June 2019	[48] [49] [83]
T1037.004	Boot or Logon Initialization Scripts: RC Scripts	Persistence, Privilege Escalation	Cyclops Blink modified S51armled RC script	[49] [83]
T1573.002	Encrypted Channel: Asymmetric Cryptography	Command and Control	Cyclops Blink C2 over TLS	[48] [83]
T1686.002	Disable or Modify System Firewall: Network Device Firewall	Defense Impairment	Cyclops Blink modifies the network device firewall (v20 numbering)	[83]
T1484.001	Domain or Tenant Policy Modification: Group Policy Modification	Defense Impairment, Privilege Escalation	CaddyWiper pushed by GPO (2022-10-12; POWERGAP, April 2022); HermeticWiper via the default domain GPO (2022-02-23)	[58] [75] [55] [52]
T1505.003	Server Software Component: Web Shell	Persistence	Neo-REGEORG web shell, access by June 2022	[58] [75]
T1543.002	Create or Modify System Process: Systemd Service	Persistence, Privilege Escalation	GOGETTER persisted as a systemd service, 2022	[75]
T1036.004	Masquerade Task or Service	Stealth	GOGETTER systemd units masqueraded as legitimate services, 2022	[75]
T1095	Non-Application Layer Protocol	Command and Control	C2 proxied in a TLS-based tunnel, 2022	[75]
T1222.001	File and Directory Permissions Modification: Windows Permissions	Defense Impairment	CaddyWiper Windows permission changes, 2022	[82]
T1057	Process Discovery	Discovery	CaddyWiper process discovery, 2022	[82]
T1203	Exploitation for Client Execution	Execution	CVE-2014-4114 exploited in the wild in a Sandworm campaign, 2014	[14] [63] [64]

13.3 ATT&CK for ICS techniques (49)

Each row is an ATT&CK for ICS technique that ATT&CK v20.0 lists on G0034, its campaigns or its software [14] [15] [16] [17] [18] [19] [75] [77] [78] [80] [81]; tactics come from `data/attack/ics/technique_profiles.jsonl` [87]. The library has no generated ICS technique pages, so ids link to attack.mitre.org; the ICS ATT&CK Technique Atlas groups them by tactic. ATT&CK v20 moved several ICS techniques to new ids. Block Communications is now `T1695` and Block OT Message `T1691`. Unauthorized Message is `T1692.001`, Modify Firmware `T1693.001`, and ICS Command and Scripting Interpreter `T1701`. Older write-ups and the book use the earlier ids [14]. The protection-related rows `T0800`, `T0837` and `T1499.004` (Part 13.2) describe Industroyer's capability; Slowik found the tool failed as built [9].

ID	Name	Tactic(s)	Dated event or report	Sources
T0800	Activate Firmware Update Mode	Inhibit Response Function	Industroyer SIPROTEC DoS (capability; Slowik found it failed as built), 2016	[17] [11] [9]
T0801	Monitor Process State	Collection	Industroyer (2016) and Industroyer2 (2022)	[17] [77]
T0802	Automated Collection	Collection	Industroyer (2016) and Industroyer2 (2022)	[17] [77]
T0806	Brute Force I/O	Impair Process Control	IEC 104 payload loops commands in range, shift or sequence modes (2016); Industroyer2 (2022)	[11] [17] [77]
T0809	Data Destruction	Inhibit Response Function	KillDisk overwrote Windows-based HMI cards in RTUs (2015); Industroyer wiper ICS file types (2016)	[1] [18] [11] [17]
T0813	Denial of Control	Impact	2015 grid: operators locked out and breakers opened remotely	[1] [2] [15] [17]
T0814	Denial of Service	Inhibit Response Function	2015: converter firmware and UPS disconnects; 2016 SIPROTEC DoS tool (capability)	[1] [15] [11] [17]
T0815	Denial of View	Impact	Industroyer, 2016	[17]
T0816	Device Restart/Shutdown	Inhibit Response Function	2015: scheduled UPS disconnects; Industroyer (2016)	[1] [15] [17]
T0817	Drive-by Compromise	Initial Access	Bad Rabbit drive-by, 2017-10-24	[81] [36]
T0819	Exploit Public-Facing Application	Initial Access	BlackEnergy campaign against internet-facing HMIs since 2011; CVE-2014-0751	[8] [14]
T0822	External Remote Services	Initial Access	2015: VPN into the ICS, probably with previously obtained credentials	[1] [2] [15]
T0823	Graphical User Interface	Execution	2015: operators' own DMS screens used to open breakers	[2] [15]
T0826	Loss of Availability	Impact	2015-12-23: outages for about 225,000 customers	[1] [15]
T0827	Loss of Control	Impact	2015 grid; Industroyer (2016)	[15] [17]

ID	Name	Tactic(s)	Dated event or report	Sources
T0828	Loss of Productivity and Revenue	Impact	2015 grid; NotPetya losses (2017); Bad Rabbit (2017)	[15] [78] [25] [28] [81]
T0829	Loss of View	Impact	KillDisk (2015); Industroyer (2016)	[18] [17]
T0830	Adversary-in-the-Middle	Collection	VPNFilter ssler man-in-the-middle module, June 2018	[43] [80]
T0831	Manipulation of Control	Impact	2015: breakers opened remotely; Industroyer (2016)	[1] [15] [17]
T0832	Manipulation of View	Impact	Industroyer, 2016	[17]
T0836	Modify Parameter	Impair Process Control	Industroyer2, 2022-04-08	[77]
T0837	Loss of Protection	Impact	Industroyer SIPROTEC DoS (capability), 2016	[17] [9]
T0840	Network Connection Enumeration	Discovery	Industroyer, 2016	[17]
T0842	Network Sniffing	Discovery	VPNFilter Modbus TCP sniffing, 2018	[42] [80]
T0846	Remote System Discovery	Discovery	2015 grid; Industroyer (2016)	[15] [17]
T0846.001	Port Scan	Discovery	Industroyer custom port scanner, 2016	[11] [17]
T0849	Masquerading	Evasion	2016: masquerading in the ICS environment	[16]
T0859	Valid Accounts	Persistence, Lateral Movement	Credentials, probably stolen, used over VPN (2015); credential re-use for deployment (2016)	[1] [15] [9] [16] [19]
T0863	User Execution	Execution	Bad Rabbit: the user must launch the dropper, 2017	[81] [37]
T0865	Spearphishing Attachment	Initial Access	BlackEnergy Office attachments, 2015	[2] [19]
T0866	Exploitation of Remote Services	Initial Access, Lateral Movement	NotPetya MS17-010 (2017); Bad Rabbit (2017)	[78] [81]
T0867	Lateral Tool Transfer	Lateral Movement	2015 grid; Dec 2016 BAT-file copies; NotPetya and Bad Rabbit (2017)	[15] [9] [16] [78] [81]
T0869	Standard Application Layer Protocol	Command and Control	BlackEnergy HTTP C2, 2015	[6] [19]
T0872	Indicator Removal on Host	Evasion	KillDisk deletes event logs, 2015	[7] [18]
T0881	Service Stop	Inhibit Response Function	KillDisk kills serial-to-Ethernet processes (2015); Industroyer (2016); Industroyer2 (2022)	[7] [18] [17] [77]
T0884	Connection Proxy	Command and Control	2015 grid; Industroyer internal proxy (2016)	[15] [11] [17]
T0885	Commonly Used Port	Command and Control	2015 grid	[15]
T0886	Remote Services	Initial Access, Lateral Movement	2015: remote administration and ICS client tools over VPN; 2016	[1] [15] [16]

ID	Name	Tactic(s)	Dated event or report	Sources
T0888	Remote System Information Discovery	Discovery	Industroyer (2016) and Industroyer2 (2022)	[17] [77]
T0894	System Binary Proxy Execution	Evasion	MicroSCADA scilc.exe run from a mounted ISO, 2022-10-10	[58] [75]
T0895	Autorun Image	Execution	a.iso mounted on the MicroSCADA hypervisor, 2022-10-10	[58] [75]
T1691.001	Block Operational Technology Message: Command Message	Inhibit Response Function	2015 grid; Industroyer (2016)	[15] [17]
T1691.002	Block Operational Technology Message: Reporting Message	Inhibit Response Function	2015 grid; Industroyer (2016)	[15] [17]
T1692.001	Unauthorized Message: Command Message	Evasion, Impair Process Control	2015 breakers; IEC 104 select-and-execute (2016); Industroyer2 and the 2022 MicroSCADA commands	[15] [11] [17] [75] [77]
T1693.001	Modify Firmware: System Firmware	Persistence, Inhibit Response Function, Impair Process Control	2015: malicious firmware uploaded to serial-to-Ethernet converters	[1] [15]
T1695.001	Block Communications: Serial COM	Inhibit Response Function	2015 grid; IEC 101 payload holds the COM ports (2016)	[15] [11] [17]
T1701.001	Command and Scripting Interpreter: PowerShell	Execution	PowerShell in the 2016 operation	[16]
T1701.002	Command and Scripting Interpreter: Windows Command Shell	Execution	Windows command shell in the 2016 operation	[16]
T1701.004	Command and Scripting Interpreter: Visual Basic	Execution	VBS in the 2016 operation	[16]

13.4 CWE and CAPEC

CVE	NVD CWE	Note	Source
CVE-2014-0751	CWE-22 Path Traversal	GE CIMPLICITY, HMI campaign	[66]
CVE-2015-5374	CWE-19	A broad category id; cited as NVD lists it	[12]
CVE-2014-4114, CVE-2017-0144, CVE-2017-0145	NVD-CWE-noinfo	No CWE to cite	[64] [24]

The library's CAPEC data maps these patterns to techniques in this record [87] (**Confirmed**):

CAPEC	ATT&CK technique	Where it meets the record
CAPEC-163 Spear Phishing	T1566.001, T1566.002	2015 Office attachments; PyeongChang lures
CAPEC-186 Malicious Software Update	T1195.002	M.E.Doc, 2017

CAPEC	ATT&CK technique	Where it meets the record
CAPEC-442 Infected Software	`T1195.002`	M.E.Doc, 2017
CAPEC-112 Brute Force	`T1110`	2016 scripted RPC authentication
CAPEC-565 Password Spraying	`T1110.003`	Bad Rabbit NTLM brute force
CAPEC-560 Use of Known Domain Credentials	`T1078`	2015 VPN access
CAPEC-650 Upload a Web Shell to a Web Server	`T1505.003`	Neo-REGEORG, 2022
CAPEC-158 Sniffing Network Traffic	`T1040`	BlackEnergy sniffer, 2015
CAPEC-638 Altered Component Firmware	`T1542.002`	Cyclops Blink
CAPEC-125 Flooding	`T1499`	Georgia website disruption, 2019

No library CAPEC maps an ICS technique. See the CWE Reference and CAPEC Reference.

13.5 D3FEND countermeasures

The library's `data/attack/technique_to_d3fend.jsonl` maps these countermeasures to the 49 ICS techniques in this record; the count is how many of the 49 each covers, and each has a library page [87] (**Confirmed**). The D3FEND API confirms OT Variable Access Restriction, Remote Firmware Update Monitoring and Operating Mode Restriction as live techniques [85].

D3FEND countermeasure	Coverage	Where it meets the record
Network Traffic Filtering (D3-NTF)	23	Blocking VPN and remote-service paths into the ICS (2015) and Industroyer's protocol traffic (2016)
Application Protocol Command Analysis (D3-APCA)	17	Spotting IEC 104 select-and-execute loops and MMS writes
Protocol Metadata Anomaly Detection (D3-PMAD)	17	Unusual ICS protocol sessions
Remote Terminal Session Detection (D3-RTSD)	17	The remote operators of December 2015
Client-server Payload Profiling (D3-CSPP)	17	Profiling ICS client traffic
Network Traffic Community Deviation (D3-NTCD)	17	New hosts talking to substations
Message Authentication (D3-MAN)	12	The unauthenticated protocols CISA describes [10]
Process Spawn Analysis (D3-PSA)	10	scilc.exe launched from a mounted ISO, 2022
Executable Allowlisting (D3-EAL)	5	HMI allowlisting [10]; not enough alone in 2022 (Part 11.3)
OT Variable Access Restriction (D3-OVAR)	4	Industroyer and Industroyer2 parameter writes

D3FEND countermeasure	Coverage	Where it meets the record
Remote Firmware Update Monitoring (D3-RFUM)	`T0800`, `T0814`	The 2015 converter firmware uploads
Operating Mode Restriction (D3-OPR)	`T0800`	Firmware update mode on protection relays
Domain Account Monitoring	Enterprise	New privileged accounts on 1 December 2016 (**Inferred** pairing)

See the D3FEND Reference.

13.6 ATT&CK for ICS mitigations

Counted across the 49 ICS techniques, ATT&CK's most frequent mitigations are Network Segmentation (M0930, 17) and Network Allowlists (M0807, 12). Out-of-Band Communications Channel (M0810, 11) and Data Backup (M0953, 9) follow, then M0937 and M0931 (8 each) and Communication Authenticity (M0802, 7) [86] (**Confirmed**). `T0801`, `T0823` and `T0840` carry M0816, ATT&CK's marker that mitigation is limited or not effective [86]. The library has no ICS mitigation pages, so these link to attack.mitre.org, for example M0810.

13.7 Navigator layers

- Enterprise: `navigator/library-layers/sandworm-operations.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20, the 78 techniques of Part 13.2, each shown under its tactics with a comment naming the event and this study's source numbers.
- ICS: `navigator/case-studies/sandworm-operations-ics.json` (open in Navigator), domain `ics-attack`, the 49 techniques of Part 13.3. Curated layers under `navigator/library-layers/` must be `enterprise-attack`, so the ICS layer lives in its own folder and is listed in the CATALOG of `scripts/build_navigator_layers.py`, which generates `navigator/index.md`.

Scores in both layers mean only that the study binds the technique to a dated Sandworm event, not severity or prevalence.

Cross-cutting themes

- **Learn by hand, then automate.** In 2015 operators clicked through three different DMS screens [2]. In 2016 Industroyer spoke the protocols itself on a timer [11], and in 2022 Industroyer2 shipped per-substation configurations [55]. Each step cut the dwell needed inside the OT network (**Inferred**).
- **Destruction follows disruption.** Every grid attack ended with a wiper: KillDisk in 2015 [1], the haslo.dat wiper in 2016 [11], CaddyWiper in April and October 2022 [54] [58]. The wipers were aimed at recovery as much as at data.
- **Disguise is part of the payload.** NotPetya posed as ransomware [5] [23], Olympic Destroyer posed as Lazarus code [5] [40], and Prestige ran as ransomware too [57]. Treat the label on the ransom note as unverified.
- **The blast radius is not the target.** NotPetya was aimed at Ukraine, per the UK [33], yet its largest recorded losses were at FedEx, Merck and Mondelez [25] [28] [29] (**Inferred** reading of those sources).
- **Overstated and understated.** Overstated: the more than $10 billion total as recorded fact, when the White House gives no figure [32]; the $870 million Merck figure is not stated in the filings, which report the

loss in parts across 2017 and 2018 [25] [26]. Also overstated: the 2016 attack's real effect [9], and attributing every 2022 wiper to Sandworm [51] [52] [53]. Understated: how much of the record ran on credentials and native tools rather than malware [2] [9] [58] (**Inferred**, this study's reading of the sources cited).

Sources

#	Source	URL	Opened	Grade
1	CISA (ICS-CERT), IR-ALERT-H-16-056-01, "Cyber-Attack Against Ukrainian Critical Infrastructure" (25 February 2016; 2021-07-20 attribution note)	https://www.cisa.gov/news-events/ics-alerts/ir-alert-h-16-056-01	3 Nov 2026	Confirmed
2	SANS ICS and E-ISAC, "Analysis of the Cyber Attack on the Ukrainian Power Grid," Defense Use Case (18 March 2016); also served at https://www.nerc.com/pa/CI/ESISAC/Documents/E-ISAC_SANS_Ukraine_DUC_18Mar2016.pdf	https://nsarchive.gwu.edu/sites/default/files/documents/3891751/SANS-and-Electricity-Information-Sharing-and.pdf	3 Nov 2026	Confirmed
3	SANS blog, "Confirmation of a Coordinated Attack on the Ukrainian Power Grid"	https://www.sans.org/blog/confirmation-of-a-coordinated-attack-on-the-ukrainian-power-grid	3 Nov 2026	Confirmed
4	ESET (Cherepanov and Lipovsky), "Industroyer: Biggest threat to industrial control systems since Stuxnet" (12 June 2017)	https://www.welivesecurity.com/2017/06/12/industroyer-biggest-threat-industrial-control-systems-since-stuxnet/	3 Nov 2026	Confirmed
5	US DOJ, indictment, *United States v. Andrienko et al.*, W.D. Pa. Criminal No. 20-316 (filed 15 October 2020), 50-page PDF	https://www.justice.gov/opa/press-release/file/1328521/download	3 Nov 2026	Confirmed
6	Kaspersky, "BlackEnergy APT attacks in Ukraine employ spearphishing with Word documents"	https://securelist.com/blackenergy-apt-attacks-in-ukraine-employ-spearphishing-with-word-documents/73440/	3 Nov 2026	Confirmed
7	ESET, "BlackEnergy by the SSHBearDoor: attacks against Ukrainian news media and electric industry" (3 January 2016)	https://www.welivesecurity.com/2016/01/03/blackenergy-sshbeardoor-details-2015-attacks-ukrainian-news-media-electric-industry/	3 Nov 2026	Confirmed
8	CISA (ICS-CERT), ICS-ALERT-14-281-01E, ongoing BlackEnergy campaign (8 October 2014, updated 17 October 2014)	https://www.cisa.gov/news-events/ics-alerts/ics-alert-14-281-01e	3 Nov 2026	Confirmed
9	Joe Slowik (Dragos), "Anatomy of an attack: detecting and defeating CRASHOVERRIDE," Virus Bulletin 2018	https://www.virusbulletin.com/uploads/pdf/magazine/2018/VB2018-Slowik.pdf	3 Nov 2026	Confirmed
10	US-CERT, TA17-163A, "CrashOverride Malware" (12 June 2017; 2021-07-20 update)	https://www.cisa.gov/news-events/alerts/2017/06/12/crashoverride-malware	3 Nov 2026	Confirmed
11	ESET, "Win32/Industroyer: A new threat for industrial control systems" white paper (June 2017)	https://web-assets.esetstatic.com/wls/2017/06/Win32_Industroyer.pdf	3 Nov 2026	Confirmed
12	NVD, CVE-2015-5374 (also read through the NVD API)	https://nvd.nist.gov/vuln/detail/CVE-2015-5374	3 Nov 2026	Confirmed
13	Dragos, ELECTRUM threat group profile	https://www.dragos.com/threat/electrum	3 Nov 2026	Confirmed
14	MITRE ATT&CK, G0034 Sandworm Team (v4.2, modified 31 July 2026)	https://attack.mitre.org/groups/G0034/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
15	MITRE ATT&CK, C0028 2015 Ukraine Electric Power Attack	https://attack.mitre.org/campaigns/C0028/	3 Nov 2026	Confirmed
16	MITRE ATT&CK, C0025 2016 Ukraine Electric Power Attack	https://attack.mitre.org/campaigns/C0025/	3 Nov 2026	Confirmed
17	MITRE ATT&CK, S0604 Industroyer	https://attack.mitre.org/software/S0604/	3 Nov 2026	Confirmed
18	MITRE ATT&CK, S0607 KillDisk	https://attack.mitre.org/software/S0607/	3 Nov 2026	Confirmed
19	MITRE ATT&CK, S0089 BlackEnergy	https://attack.mitre.org/software/S0089/	3 Nov 2026	Confirmed
20	Cisco Talos, "The MeDoc Connection" (5 July 2017)	https://blog.talosintelligence.com/the-medoc-connection/	3 Nov 2026	Confirmed
21	ESET, "TeleBots are back: Supply-chain attacks against Ukraine" (30 June 2017)	https://www.welivesecurity.com/2017/06/30/telebots-back-supply-chain-attacks-against-ukraine/	3 Nov 2026	Confirmed
22	Microsoft Security, "New ransomware, old techniques: Petya adds worm capabilities" (27 June 2017)	https://www.microsoft.com/en-us/security/blog/2017/06/27/new-ransomware-old-techniques-petya-adds-worm-capabilities/	3 Nov 2026	Confirmed
23	CISA, TA17-181A, "Petya Ransomware" (1 July 2017, revised 15 February 2018)	https://www.cisa.gov/news-events/alerts/2017/07/01/petya-ransomware	3 Nov 2026	Confirmed
24	NVD, CVE-2017-0144 (CVE-2017-0145 read the same day)	https://nvd.nist.gov/vuln/detail/CVE-2017-0144	3 Nov 2026	Confirmed
25	Merck & Co., Form 10-K for fiscal 2017	`https://www.sec.gov/Archives/edgar/data/310158/000031015818000005/mrk1231201710k.htm`	3 Nov 2026	Confirmed
26	Merck & Co., Form 10-K for fiscal 2018	`https://www.sec.gov/Archives/edgar/data/310158/000031015819000014/mrk1231201810k.htm`	3 Nov 2026	Confirmed
27	FedEx, Form 10-Q for the quarter ended 31 August 2017	`https://www.sec.gov/Archives/edgar/data/1048911/000156459017018835/fdx-10q_20170831.htm`	3 Nov 2026	Confirmed
28	FedEx, Form 10-K for fiscal 2018 (year ended 31 May 2018)	`https://www.sec.gov/Archives/edgar/data/1048911/000156459018016877/fdx-10k_20180531.htm`	3 Nov 2026	Confirmed
29	Mondelez International, Form 10-K for fiscal 2017	`https://www.sec.gov/Archives/edgar/data/1103982/000119312518037332/d466496d10k.htm`	3 Nov 2026	Confirmed
30	Mondelez International, Form 10-K for fiscal 2022	`https://www.sec.gov/Archives/edgar/data/1103982/000110398223000006/mdlz-20221231.htm`	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
31	Andy Greenberg, "The Untold Story of NotPetya," WIRED (excerpt from *Sandworm*, 2018)	https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/	3 Nov 2026	Reported
32	The White House, Statement from the Press Secretary on NotPetya (15 February 2018)	https://trumpwhitehouse.archives.gov/briefings-statements/statement-press-secretary-25/	3 Nov 2026	Confirmed
33	UK government, "Foreign Office Minister condemns Russia for NotPetya attacks" (15 February 2018)	https://www.gov.uk/government/news/foreign-office-minister-condemns-russia-for-notpetya-attacks	3 Nov 2026	Confirmed
34	UK government, "UK exposes Russian cyber attacks" (4 October 2018)	https://www.gov.uk/government/news/uk-exposes-russian-cyber-attacks	3 Nov 2026	Confirmed
35	ESET, "New TeleBots backdoor: First evidence linking Industroyer to NotPetya" (11 October 2018)	https://www.welivesecurity.com/2018/10/11/new-telebots-backdoor-linking-industroyer-notpetya/	3 Nov 2026	Confirmed
36	ESET, "Bad Rabbit: Not-Petya is back with improved ransomware" (24 October 2017, updated 27 October)	https://www.welivesecurity.com/2017/10/24/bad-rabbit-not-petya-back/	3 Nov 2026	Confirmed
37	Kaspersky, "Bad Rabbit ransomware"	https://securelist.com/bad-rabbit-ransomware/82851/	3 Nov 2026	Confirmed
38	US-CERT, "Multiple Ransomware Infections Reported" (24 October 2017)	https://www.cisa.gov/news-events/alerts/2017/10/24/multiple-ransomware-infections-reported	3 Nov 2026	Confirmed
39	Cisco Talos, "Olympic Destroyer Takes Aim At Winter Olympics" (12 February 2018)	https://blog.talosintelligence.com/olympic-destroyer/	3 Nov 2026	Confirmed
40	Kaspersky GReAT, "OlympicDestroyer is here to trick the industry" (8 March 2018)	https://securelist.com/olympicdestroyer-is-here-to-trick-the-industry/84295/	3 Nov 2026	Confirmed
41	Kaspersky GReAT, "Olympic Destroyer is still alive" (2018)	https://securelist.com/olympic-destroyer-is-still-alive/86169/	3 Nov 2026	Confirmed
42	Cisco Talos, "New VPNFilter malware targets at least 500K networking devices worldwide" (23 May 2018)	https://blog.talosintelligence.com/vpnfilter/	3 Nov 2026	Confirmed
43	Cisco Talos, "VPNFilter update" (6 June 2018)	https://blog.talosintelligence.com/vpnfilter-update/	3 Nov 2026	Confirmed
44	FBI, PSA I-052518-PSA (25 May 2018)	https://www.ic3.gov/PSA/2018/PSA180525	3 Nov 2026	Confirmed
45	SentinelLabs, "AcidRain: A Modem Wiper Rains Down on Europe" (2022)	https://www.sentinelone.com/labs/acidrain-a-modem-wiper-rains-down-on-europe/	3 Nov 2026	Confirmed (own analysis); Reported (relay of the 2018 DOJ naming)
46	NCSC, "Joint advisory shows new Sandworm malware Cyclops Blink replaces VPNFilter" (23 February 2022)	https://www.ncsc.gov.uk/news/joint-advisory-shows-new-sandworm-malware-cyclops-blink-replaces-vpnfilter	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
47	UK government, "UK condemns Russia's GRU over Georgia cyber-attacks" (20 February 2020)	https://www.gov.uk/government/news/uk-condemns-russias-gru-over-georgia-cyber-attacks	3 Nov 2026	Confirmed
48	CISA, NCSC, NSA and FBI, AA22-054A, "New Sandworm Malware Cyclops Blink Replaces VPNFilter" (23 February 2022)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-054a	3 Nov 2026	Confirmed
49	NCSC, Cyclops Blink malware analysis report (23 February 2022)	https://www.ncsc.gov.uk/files/Cyclops-Blink-Malware-Analysis-Report.pdf	3 Nov 2026	Confirmed
50	Trend Micro, "Cyclops Blink Sets Sights on Asus Routers" (17 March 2022)	https://www.trendmicro.com/en_us/research/22/c/cyclops-blink-sets-sights-on-asus-routers--.html	3 Nov 2026	Confirmed
51	Microsoft Security, "Destructive malware targeting Ukrainian organizations" (15 January 2022)	https://www.microsoft.com/en-us/security/blog/2022/01/15/destructive-malware-targeting-ukrainian-organizations/	3 Nov 2026	Confirmed
52	ESET, "IsaacWiper and HermeticWizard: New wiper and worm targeting Ukraine" (1 March 2022)	https://www.welivesecurity.com/2022/03/01/isaacwiper-hermeticwizard-wiper-worm-targeting-ukraine/	3 Nov 2026	Confirmed
53	ESET, "CaddyWiper: New wiper malware discovered in Ukraine" (15 March 2022)	https://www.welivesecurity.com/2022/03/15/caddywiper-new-wiper-malware-discovered-ukraine/	3 Nov 2026	Confirmed
54	ESET, "Industroyer2: Industroyer reloaded" (12 April 2022)	https://www.welivesecurity.com/2022/04/12/industroyer2-industroyer-reloaded/	3 Nov 2026	Confirmed
55	CERT-UA, alert #4435 on the April 2022 attack on Ukrainian energy facilities (in Ukrainian)	https://cert.gov.ua/article/39518	3 Nov 2026	Confirmed
56	Microsoft On the Issues, "The hybrid war in Ukraine" (27 April 2022)	https://blogs.microsoft.com/on-the-issues/2022/04/27/hybrid-war-ukraine-russia-cyberattacks/	3 Nov 2026	Confirmed
57	Microsoft Security, "New Prestige ransomware impacts organizations in Ukraine and Poland" (14 October 2022, updated 10 November 2022)	https://www.microsoft.com/en-us/security/blog/2022/10/14/new-prestige-ransomware-impacts-organizations-in-ukraine-and-poland/	3 Nov 2026	Confirmed
58	Mandiant (Google Cloud), "Sandworm Disrupts Power in Ukraine Using a Novel Attack Against Operational Technology" (9 November 2023)	https://cloud.google.com/blog/topics/threat-intelligence/sandworm-disrupts-power-ukraine-operational-technology/	3 Nov 2026	Confirmed
59	UK government, "Russia behind cyber-attack with Europe-wide impact an hour before Ukraine invasion" (2022)	https://www.gov.uk/government/news/russia-behind-cyber-attack-with-europe-wide-impact-an-hour-before-ukraine-invasion	3 Nov 2026	Confirmed
60	Mandiant (Google Cloud), "APT44: Unearthing Sandworm" (17 April 2024)	https://cloud.google.com/blog/topics/threat-intelligence/apt44-unearthing-sandworm	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
61	Penguin Random House, *Sandworm* by Andy Greenberg (publisher page)	https://www.penguinrandomhouse.com/books/597684/sandworm-by-andy-greenberg/	3 Nov 2026	Confirmed
62	Andy Greenberg, "How an Entire Nation Became Russia's Test Lab for Cyberwar," WIRED (2017)	https://www.wired.com/story/russian-hackers-attack-ukraine/	3 Nov 2026	Reported
63	Microsoft, Security Bulletin MS14-060 (14 October 2014)	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2014/ms14-060	3 Nov 2026	Confirmed
64	NVD, CVE-2014-4114	https://nvd.nist.gov/vuln/detail/CVE-2014-4114	3 Nov 2026	Confirmed
65	CISA, Known Exploited Vulnerabilities catalog (catalog version 2026.11.03)	https://www.cisa.gov/known-exploited-vulnerabilities-catalog	3 Nov 2026	Confirmed
66	NVD, CVE-2014-0751	https://nvd.nist.gov/vuln/detail/CVE-2014-0751	3 Nov 2026	Confirmed
67	ESET, "BlackEnergy trojan strikes again: Attacks Ukrainian electric power industry" (4 January 2016)	https://www.welivesecurity.com/2016/01/04/blackenergy-trojan-strikes-again-attacks-ukrainian-electric-power-industry/	3 Nov 2026	Confirmed
68	Andy Greenberg, WIRED (2019) on the 2016 Kyiv blackout and Dragos's reassessment	https://www.wired.com/story/russia-ukraine-cyberattack-power-grid-blackout-destruction/	3 Nov 2026	Reported
69	Cisco Talos, "New Ransomware Variant Nyetya Compromises Systems Worldwide" (27 June 2017)	https://blog.talosintelligence.com/worldwide-ransomware-variant/	3 Nov 2026	Confirmed
70	ESET, "The rise of TeleBots: Analyzing disruptive KillDisk attacks" (13 December 2016)	https://www.welivesecurity.com/2016/12/13/rise-telebots-analyzing-disruptive-killdisk-attacks/	3 Nov 2026	Confirmed
71	Andy Greenberg, "The Untold Story of the 2018 Olympics Cyberattack," WIRED (excerpt from *Sandworm*, 17 October 2019)	https://www.wired.com/story/untold-story-2018-olympics-destroyer-cyberattack/	3 Nov 2026	Reported
72	US Department of State, "The United States Condemns Russian Cyber Attack Against the Country of Georgia" (20 February 2020)	https://2017-2021.state.gov/the-united-states-condemns-russian-cyber-attack-against-the-country-of-georgia/	3 Nov 2026	Confirmed
73	FBI, wanted notice for Yuriy Sergeyevich Andrienko	`https://www.fbi.gov/wanted/cyber/yuriy-sergeyevich-andrienko`	3 Nov 2026	Confirmed
74	ANSSI, CERTFR-2021-CTI-005, Sandworm intrusion set campaign targeting Centreon systems (15 February 2021)	https://www.cert.ssi.gouv.fr/uploads/CERTFR-2021-CTI-005.pdf	3 Nov 2026	Confirmed
75	MITRE ATT&CK, C0034 2022 Ukraine Electric Power Attack	https://attack.mitre.org/campaigns/C0034/	3 Nov 2026	Confirmed
76	MITRE ATT&CK, C0063 2025 Poland Wiper Attacks	https://attack.mitre.org/campaigns/C0063/	3 Nov 2026	Confirmed
77	MITRE ATT&CK, S1072 Industroyer2	https://attack.mitre.org/software/S1072/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
78	MITRE ATT&CK, S0368 NotPetya	https://attack.mitre.org/software/S0368/	3 Nov 2026	Confirmed
79	MITRE ATT&CK, S0365 Olympic Destroyer	https://attack.mitre.org/software/S0365/	3 Nov 2026	Confirmed
80	MITRE ATT&CK, S1010 VPNFilter	https://attack.mitre.org/software/S1010/	3 Nov 2026	Confirmed
81	MITRE ATT&CK, S0606 Bad Rabbit	https://attack.mitre.org/software/S0606/	3 Nov 2026	Confirmed
82	MITRE ATT&CK, S0693 CaddyWiper	https://attack.mitre.org/software/S0693/	3 Nov 2026	Confirmed
83	MITRE ATT&CK, S0687 Cyclops Blink	https://attack.mitre.org/software/S0687/	3 Nov 2026	Confirmed
84	CISA, AA22-110A, Russian state-sponsored and criminal cyber threats to critical infrastructure (revised 9 May 2022)	https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-110a	3 Nov 2026	Confirmed
85	MITRE D3FEND API, OT Variable Access Restriction (Remote Firmware Update Monitoring and Operating Mode Restriction read the same day)	https://d3fend.mitre.org/api/technique/d3f:OTVariableAccessRestriction.json	3 Nov 2026	Confirmed
86	MITRE ATT&CK for ICS mitigations (M0810 shown; M0930, M0807, M0953, M0937, M0931, M0802, M0816 read the same day)	https://attack.mitre.org/mitigations/M0810/	3 Nov 2026	Confirmed
87	TeamStarWolf library data and pages on main: `data/attack/` (`technique_profiles.jsonl`, `ics/technique_profiles.jsonl`, `software.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, `campaign_profiles.jsonl`), `data/weaknesses/capec.jsonl`, the `mitre/` tree, `THREAT_ACTORS.md`, `MALWARE_FAMILIES.md`, `NOTABLE_INCIDENTS.md`, `CYBERSECURITY_BOOK_LIST.md`	https://github.com/TeamStarWolf/TeamStarWolf	3 Nov 2026	Confirmed

Not opened, so cited only as other sources relay them: the 2018 DOJ release on VPNFilter (relayed by [45]); Dragos's own 2017 and 2019 CRASHOVERRIDE PDFs, which returned 404 (relayed by [10] and [68]); Michael Matonis's work and the FBI flash on 2016 election-board intrusions (relayed by [71]); Maersk's annual reports; the Mondelez v. Zurich litigation record; and a 2022 edition of *Sandworm*.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors
- Malware Families
- Notable Incidents
- CVE Reference
- ICS/OT Security Reference and the ICS ATT&CK Technique Atlas
- ATT&CK Software Reference
- Cybersecurity Book List
- MITRE pages: G0034 Sandworm Team; campaigns C0028, C0025, C0034, C0063; software S0089 BlackEnergy, S0607 KillDisk, S0604 Industroyer, S0368 NotPetya, S0606 Bad Rabbit, S0365 Olympic Destroyer, S1010 VPNFilter, S0687 Cyclops Blink, S0693 CaddyWiper, S1072 Industroyer2, S1058 Prestige, S1125 AcidRain, S0002 Mimikatz, S0029 PsExec; and the technique pages linked in Part 13.2
- CWE Reference, CAPEC Reference, D3FEND Reference
- Studies: Stuxnet: The Case Study; The Year 2019 in Intrusions: A Dated Record; The Year 2020 in Intrusions: A Dated Record; Industrial Control System Attacks and Advisories, 2024 to 2026
- Navigator layers, including this study's layers, sandworm-operations.json and sandworm-operations-ics.json
- All case studies